

06 — Security & Data Protection

1. Data in transit

- All client ↔ server traffic over **HTTPS/TLS**; realtime over **WSS**.
- API hosts (Vercel/Railway) terminate TLS; HSTS in effect.

2. Data at rest

- PostgreSQL managed instance (Railway), provider-encrypted at rest.
- **User wallet secrets** encrypted with **AES-256-GCM** (per-user key derived from PIN + server secret; see Doc 04).
- **PINs / staff passwords** stored only as **bcrypt** hashes (cost 12).
- No card data is stored (no card acquiring).

3. Secrets management

Secret	Role
WALLET_DERIVATION_SECRET	Derives user wallets — highest sensitivity
ENCRYPTION_KEY (+ _PREVIOUS)	At-rest key encryption + rotation
JWT_SECRET	Session token signing
Stellar platform keys (gas/fee)	Platform wallet signing
Partner API keys, push keys, DB URL	Integrations

- Held as platform environment variables with restricted access.
- **Rotation**: at-rest encryption key supports dual-key rotation; partner/API keys rotated on a schedule and on suspected exposure.
- **Roadmap**: move wallet-derivation + signing into a **KMS/HSM-backed signing service** so application servers never handle raw user keys.

4. Authentication & access control

- Users: phone + PIN → JWT (short-lived) + refresh token.
- Staff/admin: separate identities, **role-based access control** (super-admin, department heads, department staff), least privilege by department.
- Sensitive operations require a **multi approver** workflow.
- **Lockouts**: users (5 fails / 30 min) and staff logins; logged as security events.

5. Application security

- Server-side validation (schema validation) on all inputs.
- Rate limiting on sensitive endpoints and socket events.

- Pre-flight **fraud/risk screening** before value movement (Doc 05).
- Async errors are contained so a single failure cannot hang the service.

6. Infrastructure & monitoring

- Managed hosting (Vercel frontend, Railway backend + Postgres).
- **Error tracking:** Sentry (frontend + backend).
- **Ops monitor:** automated reconciliation, security, and fraud checks with throttled operator alerts (webhook + push).
- Audit logs for admin/staff actions and approvals.

7. Privacy & messaging

- Chat is designed around private messaging; message **previews are not shown on lock-screen notifications** (sender name + generic preview only).
- Personal data is collected for KYC/operation only; access is role-restricted.
- Data-subject handling and retention per applicable law: **[policy]**.

8. Incident response

- **[policy]** Documented IR plan: detection (Sentry + ops alerts) → triage → containment (freeze accounts, rotate secrets) → notification → post-mortem.
- Ability to **freeze** an account and to **block** transactions exists in the platform.
- Breach-notification obligations per applicable law: **[policy]**.

9. Business continuity

- Database backups: **[state cadence/retention]**.
- The deterministic wallet model means user wallets can be re-derived for recovery from the master secret + phone (Doc 04) — protect that secret accordingly.

10. Honest security-maturity summary

Area	Status
TLS everywhere, hashed PINs, AES-GCM key encryption	Live
RBAC + multi-approver + lockouts + audit logs	Live
Risk screening + reconciliation + ops alerting	Live
KMS/HSM-backed signer (key isolation)	Planned (top priority)
Independent pen-test / security audit	[planned / done]
Formal IR plan, backup policy, DPO/privacy policy	[confirm status]